

# 프라이버시 (Privacy) 설계

## ❖ 프라이버시 설계 개요

## ❖ 활동 기반 설계

- 데이터 설계
- 모델 학습 설계
- 추론 서비스 설계
- 배포 · 운영 설계

## ❖ 구조적 설계 패턴

# 프라이버시 설계 개요

- ❖ AI 시스템이 필요한 최소한의 개인정보만 수집·사용하고, 학습·추론·운영 전 과정에서 비인가 접근과 정보 노출·재식별 위험을 통제하도록 설계

## 01

### 데이터 설계

- 수집 데이터 필터링
- 데이터 최소화
- 비식별화
- 데이터 합성

## 02

### 모델 학습 설계

- 연합 학습
- 차분 프라이버시 기반 학습
- 기계 망각

## 03

### 추론서비스 설계

- 민감정보·프라이버시 공격 입력통제
- 입력 정밀도 축소
- 민감정보 출력 통제
- 출력 개인정보 비식별화

## 03

### 배포·운영 설계

- 프라이버시 감사로그 관리
- 프라이버시 위험 감시/운영 조치

## 구조적 설계 패턴

중앙 정책 기반 프라이버시 통제 패턴, 데이터 격리·프라이버시 영역 분리 패턴, 분산·로컬 우선 처리 패턴

---

# 데이터 설계

## 프라이버시를 위한 데이터 설계 기법

| 기법                     | 설명                                                                                           |
|------------------------|----------------------------------------------------------------------------------------------|
| <b>DD-1 수집 데이터 필터링</b> | 유입 시점의 실시간 PII 탐지 및 마스킹을 통해 부적절한 데이터의 시스템 유입을 원천 봉쇄하고, 데이터 저장소의 오염을 선제적으로 방어함.               |
| <b>DD-2 데이터 최소화</b>    | 불필요한 속성 제거 및 핵심 특징량 추출(Feature Extraction)을 통해 데이터 노출 면적을 구조적으로 축소하고 침해 사고 발생 시 피해 규모를 최소화함. |
| <b>DD-3 비식별화</b>       | 가명화, 마스킹, 범주화 등의 기술적 변환을 통해 정보주체와의 연결 고리를 차단함으로써, 데이터의 유용성을 유지하면서도 식별 가능성을 물리적으로 분리함.        |
| <b>DD-4 데이터 합성</b>     | 원본의 통계적 특성만 복제한 가상의 데이터를 생성하여 학습에 활용함으로써, 실제 데이터 노출 위험을 제로화하고 데이터 부족 문제를 동시에 해결함.            |

# DD-1: 수집 데이터 필터링

---

## ❖ 개념

- 데이터가 시스템으로 유입되는 시점에 실시간으로 개인식별정보 (PII)를 탐지하여 마스킹하거나 제거함으로써, 민감 데이터의 유입을 입구에서 차단

## ❖ 설계기법

- **PII 탐지 규칙과 AI 기반 탐지 모델을 결합**
  - ✓ 정규표현식·체크섬으로 주민등록번호, 전화번호, 카드번호 등 정형 PII 탐지
  - ✓ NER·문맥 분석 모델로 이름, 주소, 진료정보 등 비정형·문맥 의존 PII 탐지
- 탐지 결과에 따른 처리 정책 적용
  - ✓ 불필요한 PII → 제거 또는 입력 차단
  - ✓ 필요한 PII → 마스킹·가명화·토큰화한 후 시스템에 전달
  - ✓ 판단이 불확실하거나 고위험 정보 → 보류 또는 관리자 검토
- 실시간 필터링 파이프라인 구성
  - ✓ 입력 수신 → PII 탐지 → 위험도·권한 판단 → 제거/마스킹/보류 → 안전한 데이터 전달

## ❖ 주의

- 실시간 탐지로 인한 응답 지연을 관리하고, 입력 원문이나 탐지된 PII를 로그에 그대로 저장하지 않음
- 원본 PII가 필요한 경우에도 허가된 처리 영역에만 전달하고 최소한으로 노출

## DD-2: 민감 속성 최소화

---

### ❖ 개념

- 모델의 목적 달성에 반드시 필요한 민감 속성만 사용하고, 불필요한 속성이나 지나치게 상세한 정보는 제거·변환하여 개인정보 노출과 오용 위험을 줄이는 설계 원칙
- 데이터 유출 사고 시 공격자가 얻을 수 있는 정보의 가치와 피해 범위를 구조적으로 낮춤

### ❖ 설계 기법 (학습·검증·운영 데이터에 동일한 기법 적용)

- ① 모델 목적과 각 속성의 필요성을 연결한 **속성 필요성 목록** 작성
- ② 이름·주민등록번호 등 **불필요한 직접 식별자 제거**
- ③ 생년월일·주소 등의 세부 값을 연령대·지역 단위로 **일반화·범주화**
- ④ 민감 속성의 학습 기여도와 제거 전후 성능 비교
- ⑤ 보유 목적이 끝난 원본 속성은 삭제하거나 별도 격리

### ❖ 주의

- 과도한 제거로 정확성이 저하되거나 대리변수를 통해 민감정보가 추론될 수 있음
- 공정성 평가용 민감 속성은 모델 입력과 분리하여 통제된 환경에 보관

## DD-3: 민감 속성 비식별화

---

### ❖ 개념

- **가명화, 마스킹, 변형, 정밀도 축소** 등의 변환을 통해 특정 데이터와 정보주체 사이의 연결고리를 논리적으로 차단
- 데이터의 유용성은 유지하면서도 개별 데이터가 누구의 것인지 알 수 없게 함으로써, 데이터 활용과 프라이버시 보호를 달성

### ❖ 예시

- 고객 ID를 해시(Hash) 처리하여 **가명화**하고, 구체적인 결제 금액을 '10만원 단위'로 **범주화**하여 개별 거래의 특이성을 제거함.

### ❖ 주의

- 여러 비식별 데이터가 결합될 경우 발생하는 '**모자이크 효과(Mosaic Effect)**'에 의해 특정 개인이 다시 식별될 가능성이 있으므로, K-익명성 등 통계적 안전성 검증이 동반되어야 함.
    - ✓ **모자이크 효과**: 개별적으로 보면 누군지 알 수 없는 파편화된 정보들이지만, 이것들이 결합(Linkage)되는 순간 마치 조각들이 모여 하나의 큰 그림(모자이크)을 완성하듯 특정 개인을 식별해내는 현상
- 비식별 정보**(성별, 나이, 직업 같은 준식별자) + **공개 정보**(SNS 프로필) → **개인 식별(PII)**



# 비식별화 기법

| 분류     | 주요 기법              | 설명                                       | 예                                                                                                                                                                              |
|--------|--------------------|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 가명화    | 해싱 / 토큰화           | 식별자를 고유한 대체 값으로 치환하여 직접적인 연결 고리 차단       | <ul style="list-style-type: none"> <li>• 성명: 홍길동 → ID_A84F9</li> <li>• 주민 번호 → SHA-256 해시 값</li> </ul>                                                                         |
| 마스킹    | 삭제 / 부분 마스킹        | 식별 위험이 높은 항목을 아예 제거하거나 특수문자로 은닉          | <ul style="list-style-type: none"> <li>• 전화번호: 010-1234-5678 → 010-****-5678</li> <li>• 주소: 서울시 강남구 역삼동 → 서울시 강남구</li> </ul>                                                   |
| 통계적 변환 | 총계처리 (Aggregation) | 개별 레코드가 아닌 집합의 합계, 평균 등의 통계치로 변환         | <ul style="list-style-type: none"> <li>• 개별 연봉 → 부서원 전체 평균 연봉</li> <li>• 가계 지출 → 지역별 총 지출액 합계</li> </ul>                                                                       |
| 변형     | 노이즈 주입 / 교환        | 실제 값에 수학적 노이즈를 더하거나 임의로 값을 교환            | <ul style="list-style-type: none"> <li>• 나이: 27세 → 27 + Noise</li> <li>• 성별: 일부 샘플의 성별을 무작위로 교체(Swapping)</li> </ul>                                                           |
| 정밀도 축소 | 구간화 / 일반화 / 격자화    | 데이터의 해상도(Resolution)를 낮추어 개별 데이터의 특이성 제거 | <ul style="list-style-type: none"> <li>• 연령: 23세, 28세 → 20대 (Binning)</li> <li>• 직업: 자바 개발자 → 엔지니어 (Generalization)</li> <li>• 좌표: 상세 좌표 → 500m 격자 ID (Gridization)</li> </ul> |

# 비식별화: K-익명성

---

## ❖ 개념: 데이터셋 내의 정보 주체를 '군중 속에 숨기는 기술'

- 데이터셋에서 식별자(이름 등)를 제거하더라도, 남아있는 준식별자(Quasi-identifier)들의 조합이 데이터셋 내에 최소  $k$ 개 이상 존재하도록 하여 특정 개인을 식별할 수 없게 만드는 기법
- **준식별자**: 우편번호, 성별, 나이와 같이 단독으로는 식별이 어려우나, 결합하면 특정 개인을 추론할 수 있는 정보.
- **핵심 원리**: 동일한 준식별자 값을 가진 레코드를  $k$ 개 이상으로 묶어, 특정 레코드가 누구인지 맞춤 확률을  $1/k$  이하로 낮춤

## ❖ K-익명성을 달성하기 위한 2대 기술

- **정밀도 축소(Coarsening)**: 데이터의 정밀도/상세도를 낮춤
  - ✓ 구간화(Binning), 일반화(Generalization), 격자화(Gridization)
  - ✓ 예: 주소(서울시 강남구 역삼동) → 구 단위(서울시 강남구), 나이(27세) → 연령대(20대).
- **억제/삭제 (Suppression)**
  - ✓  $k$ 개의 조건을 충족하지 못하는 소수의 특이치(Outlier) 레코드를 아예 삭제하여 데이터셋에서 제외

## DD-4: 데이터 합성(Synthesis)

---

### ❖ 개념

- 원본 데이터의 분포·상관관계 등 통계적 특성을 학습하여, 실제 개인과 직접 대응하지 않는 가상의 데이터를 생성하는 기법
- 실제 개인정보의 사용과 공유를 줄이면서 모델 학습·시험에 필요한 데이터를 확보하는 데 활용

### ❖ 설계 기법

- ① 합성 목적과 보존할 특성·보호할 속성을 정의
- ② **GAN, VAE 등을 이용해 합성 데이터 생성**
- ③ 실제 데이터와 **합성 데이터를 분리하여 저장·관리**
- ④ 분포·상관관계·모델 성능을 비교하여 **유용성 검증**
- ⑤ 재식별·멤버십 추론·최근접 원본 비교를 통해 **프라이버시 위험 평가**
- ⑥ 기준을 충족한 데이터만 학습·공유하도록 품질 게이트 적용

### ❖ 주의

- 생성 모델이 원본 데이터를 과적합하여 학습할 경우, 합성된 데이터에서 원본의 샘플이 그대로 출력되는 '개인정보 암기(Memorization)' 현상이 발생할 수 있음.

# 데이터 설계 기법 요약

|   | 기법         | 역할          | 상세 메커니즘                                                                                     | 효과                                                                |
|---|------------|-------------|---------------------------------------------------------------------------------------------|-------------------------------------------------------------------|
| 1 | 수집 데이터 필터링 | Gate-keeper | PII 탐지 알고리즘, 정규표현식, DLP(데이터 유출 방지) 솔루션을 입구에 배치                                              | <b>위험원 유입 차단:</b> 민감 정보가 유입 경로를 봉쇄하여 리스크를 최소화함                    |
| 2 | 데이터 최소화    | Reducer     | <b>Feature Selection:</b> 분석 목적과 무관한 속성 제거<br><b>TTL(Time-to-Live):</b> 필요 기간 경과 후 자동 폐기 설계 | <b>공격 표면 축소:</b> 보유 데이터양을 최소화하여 유출 사고 발생 시 피해 규모를 물리적으로 제한함       |
| 3 | 비식별화       | Protector   | 가명화, 마스킹, 범주화 기술 적용 및 <b>K-익명성</b> 등의 통계적 안전성 검증                                            | <b>식별성 제거:</b> 실제 데이터의 통계적 유용성은 보존하되, 특정 개인과 정보 사이의 논리적 연결 고리를 끊음 |
| 4 | 데이터 합성     | Protector   | GAN, VAE 등 생성형 AI를 활용하여 원본의 통계적 특성만 복제한 <b>합성 데이터</b> 생성                                    | <b>개인정보 제로화:</b> 실제 정보주체와 무관한 가상 데이터를 생성하여, 유출 리스크를 제거함           |

---

# 모델 학습 설계

## 모델 학습 설계 기법 요약

| 기법                  | 설명                                                                                              |
|---------------------|-------------------------------------------------------------------------------------------------|
| MT-1 연합 학습          | 데이터 원본을 로컬 환경에 유지한 채 모델 가중치만 전송·결합함으로써, 데이터의 중앙 집중화에 따른 대규모 유출 리스크를 원천적으로 제거함.                  |
| MT-2 차분 프라이버시 기반 학습 | 학습 과정에 수학적 노이즈를 주입하여 특정 데이터의 기여도를 모호하게 만듦으로써, 모델의 개별 샘플 암기를 방지하고 역추론 공격에 대한 수학적 증명 가능한 보안을 제공함. |
| MT-3 기계 망각          | 학습된 모델에서 특정 데이터의 영향력만 정밀하게 제거(Unlearning)하여, 학습에 사용된 데이터의 삭제 요청에 대한 기술적 권리 이행을 보장함.             |

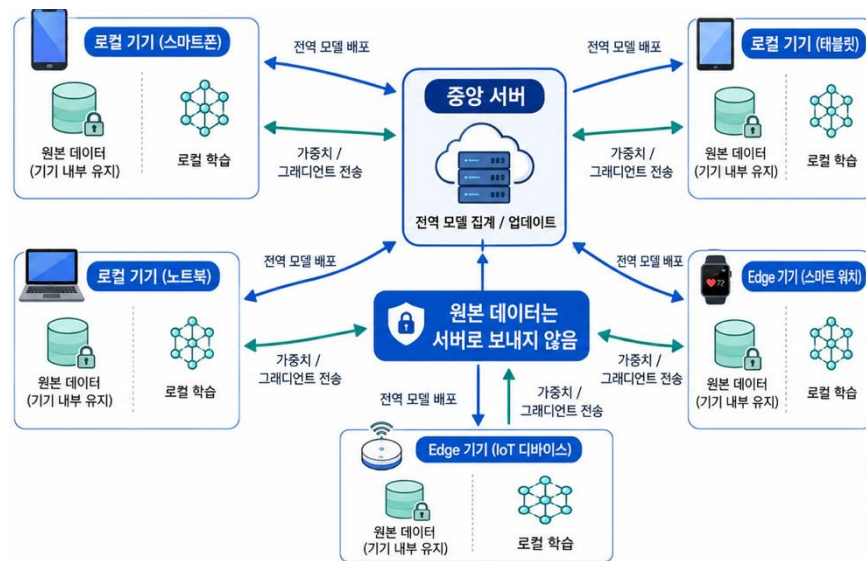
# MT-1: 연합 학습 (Federated Learning)

## ❖ 개념

- 원본 데이터는 개별 로컬 기기에 그대로 둔 채, 학습을 통해 도출된 모델의 가중치(Weights) 또는 그래디언트(Gradients)만 중앙 서버로 전송하여 전체 모델을 업데이트하는 분산형 학습 기법

## ❖ 주의

- 전송되는 가중치 값을 역추적하여 원본 데이터를 유추하는 '그래디언트 역전 공격(Inversion Attack)' 대비 필요
- 특정 클라이언트가 악의적인 데이터를 학습시켜 모델 전체를 오염시키는 '데이터 포이즈닝(Poisoning)' 리스크에 대비 필요



## MD-2: 차분 프라이버시 (Differential Privacy) 기반 학습

### ❖ 개념

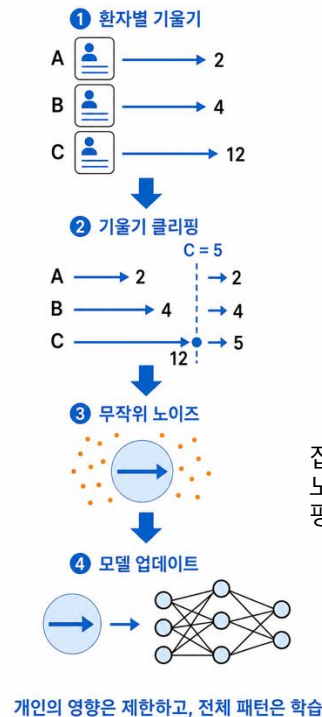
- 학습 데이터셋에 **수학적 노이즈**를 주입하여, 결과물인 모델에서 특정 개별 데이터 샘플의 기여도를 모호하게 만듦으로써 정보의 노출을 수학적으로 제한하는 기법

### ❖ 예시 (당뇨병 예측 모델 학습)

1. 개별 환자별 기울기 계산
2. 환자별 기울기 크기 제한(클리핑)
3. 기울기의 집계값에 무작위 노이즈 추가
4. 모델 업데이트

### ❖ 주의

- 프라이버시 보호 강도(Epsilon)를 높이기 위해 노이즈를 과도하게 주입할 경우, 모델의 유용성(Utility)이 급격히 하락하는 '프라이버시-유용성 트레이드오프'가 발생





# 기계 망각 (Machine Unlearning)

---

## ❖ 개념

- 기존 모델에서 특정 데이터군이나 개인 정보의 영향력만을 정밀하게 제거하여, 해당 데이터를 학습하지 않은 것과 유사한 상태로 모델을 업데이트

## ❖ 기법

- **전체 재학습**: 삭제 데이터를 제외하고 모델 전체를 처음부터 다시 학습  
→ 가장 확실하지만 시간과 비용이 큼
- **SISA 기반 부분 재학습**: 데이터를 분할해 학습해 두고, 삭제 데이터가 포함된 부분만 다시 학습  
→ 반복적인 삭제 요청에 효율적이지만 사전 구조 설계가 필요
- **근사 망각**: 영향 함수, 그래디언트 조정, 미세조정 등으로 해당 데이터의 영향을 근사적으로 제거  
→ 빠르지만 영향이 완전히 제거되지 않을 수 있음

## ❖ 주의

- 딥러닝 모델의 복잡한 구조상 특정 지식만 완벽하게 제거하는 것은 매우 어려우며, 망각 공정 중 삭제 대상과 관련 없는 일반 지식까지 함께 소실되는 '파괴적 망각(Catastrophic Forgetting)' 현상이 발생할 수 있음

---

## 추론 서비스 설계

# 프라이버시를 위한 추론 서비스 설계 기법 요약

| 단계 세부 영역 | 핵심 설계 기술            |                                                |
|----------|---------------------|------------------------------------------------|
| 입력 통제    | IS-1 민감 정보 입력 통제    | 입력과 세션 맥락에서 개인정보·민감정보를 탐지하여 삭제·마스킹·보류·차단       |
|          | IS-2 프라이버시 공격 입력 통제 | 반복·유사·미세 변형 질의를 분석하여 정보 추출·재식별 공격을 탐지하고 제한     |
|          | IS-3 입력 정밀도 축소      | 입력값을 반올림·범주화·공간 일반화하여 불필요한 상세정보와 식별 가능성을 축소    |
| 출력 통제    | IS-4 민감 정보 출력 통제    | 현재·이전 출력을 함께 검사하여 직접 노출과 누적 재식별 위험을 평가하고 출력 제한 |
|          | IS-5 출력 개인정보 비식별화   | 출력의 개인정보를 삭제·마스킹·일반화·가명화하고 잔여 개인정보를 재검사        |

## ❖ 개념

- 사용자 입력의 단일 내용뿐 아니라 세션 내 누적된 대화 맥락을 실시간으로 검사하여, 개인정보(PII)나 개인 재식별 위험이 감지되면 입력 전달을 차단·마스킹·보류

## ❖ 설계 기법

1. **패턴·의미 기반 탐지:** 주민등록번호·계좌번호와 같은 정형 패턴뿐 아니라, 개체명 인식과 분류 모델을 이용해 문맥상 개인정보나 민감정보에 해당하는 표현까지 탐지
2. **세션 맥락 결합 분석:** 현재 입력만 검사하지 않고 이전 대화에서 누적된 정보들을 결합하여, 개별 정보는 무해하더라도 함께 사용될 때 특정 개인을 식별할 수 있는 재식별 위험을 평가
3. **위험도 평가 및 조치:** 탐지된 민감정보의 종류·민감도와 세션 정보의 결합에 따른 재식별 가능성을 종합하여 위험 수준을 산정하고, 설정된 임계값에 따라 허용·마스킹·보류·차단 조치를 결정

## ❖ 주의

- 개별적으로 무해한 정보도 결합되면 개인을 식별하는 **모자이크 효과**가 발생할 수 있음
- 정상 입력을 과도하게 차단하는 오탐과 변형·은어·오타로 민감정보를 놓치는 미탐에 주의해야 함

## ❖ 개념

- 현재 입력과 세션 내 질의 이력을 분석하여, 프롬프트 인젝션이나 모델·학습 데이터의 정보를 탐색하려는 공격성 입력을 모델에 전달하기 전에 탐지·제어하는 기법

## ❖ 설계 기법

- ① 금지 명령·우회 표현 등 공격 패턴 탐지
- ② 반복·유사·미세 변형 질의의 행위 패턴 분석
- ③ 이전 질의와 현재 입력의 세션 맥락 결합 분석
- ④ 입력의 공격 유형과 위험도 평가
- ⑤ 위험도에 따른 입력 허용·재작성 요청·보류·차단

## ❖ 주의

- 반복·유사 질의가 반드시 공격은 아니므로 정상 사용의 오탐에 주의해야 함.

## ❖ 개념

- 입력 피처가 가진 데이터의 정밀도/상세도를 낮추어 특정 개인의 식별 가능성을 모호하게 만드는 기법

## ❖ 설계 기법

- ① 보호할 속성과 필요한 업무 정밀도 식별
- ② 정밀도 축소 기법 선택 및 적용

구간화, 반올림 및 절삭, 양자화, 일반화, 상위/하위 제거, 격자화, 시간 해상도 조절

- ④ 축소 전후의 재식별 위험, 모델 성능 및 서비스 유용성 검증

## ❖ 주의

- 정밀도 축소만으로 프라이버시가 보장되지는 않으며, 다른 속성과 결합하면 여전히 개인이 재식별될 수 있음.
- 지나치게 축소하면 모델 정확도와 소수집단 분석 능력이 저하될 수 있음

# 정밀도 축소 기법

| 타입  | 기법                                  | 설명                                     | 예                                                                                                                                |
|-----|-------------------------------------|----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------|
| 수치형 | 구간화<br>(Binning / Bucketing)        | 연속적인 수치를 정해진 범위(Bin)로 묶어 개별 값의 특이성을 제거 | <ul style="list-style-type: none"> <li>• 연령: 23세, 28세 → <b>20대</b></li> <li>• 소득: 4,200만 원 → <b>4,000~5,000만 원 구간</b></li> </ul> |
|     | 반올림 및 절삭<br>(Rounding / Truncation) | 하위 자릿수를 버리거나 반올림하여 수치의 정밀도를 의도적으로 낮춤   | <ul style="list-style-type: none"> <li>• 몸무게: 72.45kg → <b>72kg</b></li> <li>• 연봉: 5,123,400원 → <b>5,100,000원</b></li> </ul>     |
|     | 양자화<br>(Quantization)               | 데이터를 제한된 비트 수나 대표 상태값으로 압축하여 변환        | • 센서값: 수천 단계의 측정치 → <b>Low / Medium / High</b>                                                                                   |
| 범주형 | 일반화<br>(Generalization)             | 계층 구조(Taxonomy)를 따라 상세 속성을 상위 개념으로 치환  | <ul style="list-style-type: none"> <li>• 직업: 자바 개발자 → <b>소프트웨어 엔지니어</b></li> <li>• 질병: A형 독감 → <b>호흡기 질환</b></li> </ul>          |
|     | 상위/하위 제거<br>(Top/Bottom Coding)     | 식별 위험이 큰 극단적 희귀값들을 하나의 범주로 통합 관리       | • 고령층: 91세, 95세 → <b>'90세 이상'으로 통합 표기</b>                                                                                        |
| 시공간 | 격자화<br>(Gridization / Aggregation)  | 상세 좌표를 특정 크기의 격자 영역이나 행정 구역 대표값으로 변환   | • GPS: (37.566, 126.978) → <b>500m 격자 ID 또는 '강남구'</b>                                                                            |
|     | 시간 해상도 조절<br>(Time Truncation)      | 초, 분 단위의 상세 기록을 시간 또는 일 단위로 뭉뚱그려 변환    | • 로그: 14:22:15 → <b>14:00 또는 '오후 시간대'</b>                                                                                        |

## ❖ 개념

- 현재 모델 출력과 세션 내 이전 출력을 함께 검사하여, 개인정보·민감정보의 **직접 노출**이나 여러 응답의 결합으로 발생하는 **재식별 위험**을 평가하고, 사용자에게 전달하기 전에 **마스킹·일반화·보류·차단**하는 출력 가드레일 기법

## ❖ 설계 기법

- ① 정규표현식·개체명 인식·민감정보 분류기를 이용한 **현재 출력 검사**
- ② 현재 출력과 이전 응답을 결합한 **누적 노출 분석**
- ③ 정보의 민감도·식별 가능성·누적 공개량에 따른 **위험도 평가**
- ④ 위험 수준에 따라 민감정보 마스킹·범주화·요약·안전 응답 전환·보류·차단

## ❖ 예시

- **현재 출력 검사**: 모델이 답변 중 "A 고객님의 계좌번호는 123-456..."과 같이 실제 개인정보 패턴을 생성하면, 가드레일이 이를 탐지하여 전송을 중단함.
- **누적 노출 분석**: 이전 응답에서 "거주지"와 "직장"을 이미 제공한 상태에서, 이번 응답에 "특이 질병" 정보가 포함될 경우 특정 개인을 식별할 수 있는 확률이 임계치(예: 90%)를 넘는다고 판단하여 해당 출력을 거부하고 세션을 초기화함.



## ❖ 개념

- 모델 출력에서 개인정보·민감정보를 탐지하고, 사용자에게 전달하기 전에 마스킹·삭제·일반화·가명화하여 개인 식별 및 정보 노출 위험을 낮추는 출력 가드레일 기법

## ❖ 설계 기법

- ① 정규표현식·사전·개체명 인식 모델을 이용한 **개인정보 탐지**
- ② 정보 유형과 업무 필요성에 따른 **노출 위험도 평가**
- ③ 마스킹·삭제·일반화·가명 토큰 치환 중 적절한 방식 선택
- ④ 비식별화된 결과를 재검사한 후 출력

## ❖ 예시

- 모델이 "홍길동 님의 예약 시간은 2시입니다"라고 생성하면, 이를 가드레일에서 가로채 "고객님의 예약 시간은 2시입니다" 또는 "홍\*동 님의 예약 시간은 2시입니다"로 변환하여 전송함.

## ❖ 주의

- 가명화된 정보도 원본과 연결할 수 있으면 여전히 개인정보이며, 다른 정보와 결합하면 재식별될 수 있음. 과도한 마스킹은 답변의 의미와 유용성을 떨어뜨리고, 미탐은 개인정보를 노출할 수 있음

---

## 배포 · 운영 관점 설계

## 프라이버시를 위한 배포 · 운영 설계 기법 요약

| 단계 세부 영역   | 핵심 설계 기술                |                                                              |
|------------|-------------------------|--------------------------------------------------------------|
| 운영감시       | DO-1 프라이버시 감사 로그 관리     | 개인정보 접근·처리·위험 판정·보호조치 이력을 최소한으로 기록하고 무결성·접근권한·보존기간을 관리       |
| 운영 감시 · 조치 | DO-2 프라이버시 위험 감시 · 운영조치 | 개인정보 노출·비인가 접근·반복 질의 및 누적 재식별 위험을 감시하고, 위험 임계값 초과 시 운영조치와 연계 |

## ❖ 개념

- 개인정보의 접근·이용·제공과 프라이버시 보호조치 이력을 검증 가능한 형태로 기록·보존하여, 정책 준수 여부를 감사하고 사고 발생 시 원인과 책임 범위를 추적할 수 있도록 하는 기법

## ❖ 설계 기법

- ① 접근 주체, 시간, 목적, 대상 데이터, 수행 작업 및 처리 결과 기록
- ② 입력·출력 검사 결과와 마스킹·차단·권한 거부 등의 보호조치 기록
- ③ 정책·모델·가드레일 버전과 판단 근거 기록
- ④ 로그의 암호화, 접근제어, 무결성 검증 및 시간 동기화
- ⑤ 보존 기간 만료 시 안전한 삭제

## ❖ 주의

- 감사 로그에 원본 개인정보나 전체 프롬프트·응답을 과도하게 저장하면 로그 자체가 새로운 유출원이 될 수 있음

## ❖ 개념

- 운영 중 발생하는 개인정보·민감정보 노출, 비인가 접근, 반복적인 정보 탐색 및 여러 응답의 결합에 따른 재식별 위험을 지속적으로 관찰하고 평가하는 기법

## ❖ 설계 기법

- ① 개인정보 접근 및 입·출력 위험 이벤트 수집
- ② 민감정보 노출 정도, 사용자 권한, 접근 빈도, 반복·유사 질의 등을 기반으로 위험 등급 산정
- ③ 사용자·세션·데이터별 누적 노출 위험 추적
- ④ 위험 수준별 경고·조치 임계값 설정
- ⑤ 임계값 초과 시 추가 인증, 요청 제한, 세션 차단 등의 운영조치와 연계

| 위험 수준 | 대표 운영조치                                               |
|-------|-------------------------------------------------------|
| 낮음    | 이벤트 기록, 사용자 경고, 추가 모니터링                               |
| 보통    | 응답 상세도·질의 횟수 제한, 추가 인증 요구                             |
| 높음    | 요청 보류, 세션 종료, 계정·API 키 일시 제한, 관리자 검토                  |
| 심각    | 관련 접근 즉시 차단, 서비스 일부 격리, 증거 보존, 영향 범위 분석 및 사고 대응 절차 가동 |

---

## 구조적 설계 패턴

## 강건성 설계 패턴 개요

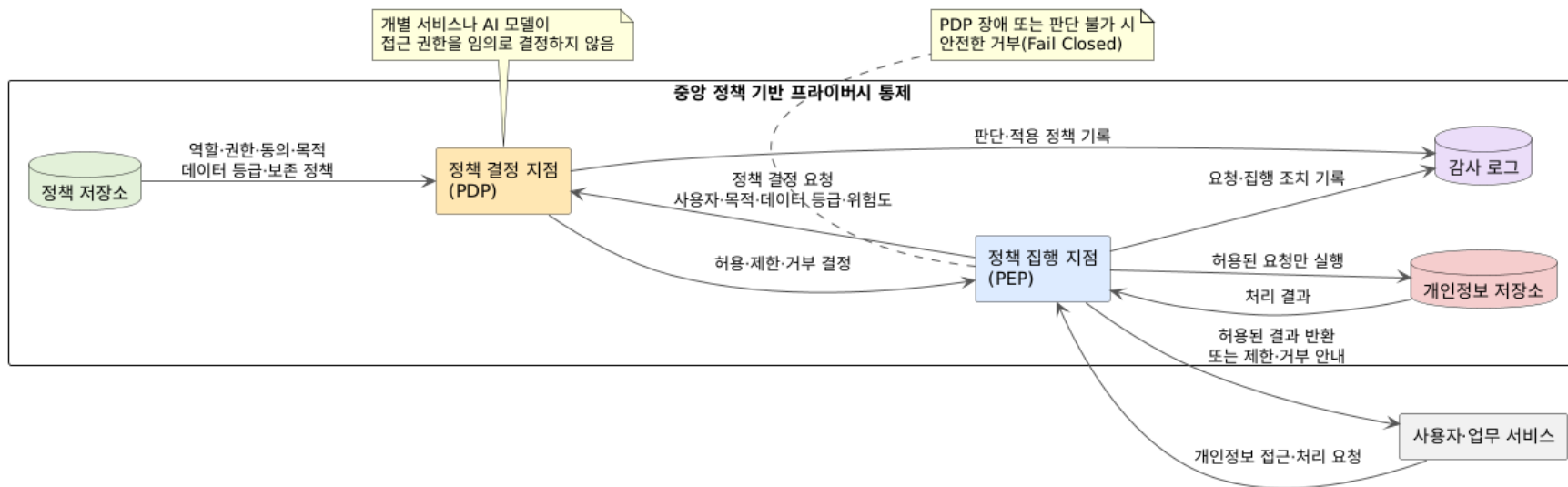
---

| 구조적 패턴                | 핵심 목적                                     |
|-----------------------|-------------------------------------------|
| 중앙 정책 기반 프라이버시 통제 패턴  | 접근·처리·출력 요청을 중앙 정책에 따라 일관되게 허용·제한         |
| 데이터 격리·프라이버시 영역 분리 패턴 | 원본 개인정보, 비식별 데이터, 모델·서비스 영역을 물리적·논리적으로 분리 |
| 분산·로컬 우선 처리 패턴        | 원본 데이터를 중앙으로 모으지 않고 데이터가 존재하는 위치에서 처리     |

# 중앙 정책 기반 프라이버시 통제 패턴

## ❖ 기본 개념

개인정보 접근과 처리를 개별 서비스가 임의로 판단하지 않고, **중앙 프라이버시 정책 결정 컴포넌트**가 사용자 권한·업무 목적·데이터 등급·위험도를 평가하여 허용 여부를 결정





# 중앙 정책 기반 프라이버시 통제 패턴

---

## ❖ 장점

- 서비스별로 흩어진 프라이버시 규칙을 일관되게 적용
- 모델이 접근권한을 자율적으로 판단하는 위험 방지
- 정책 변경 시 모든 서비스를 개별 수정할 필요가 적음

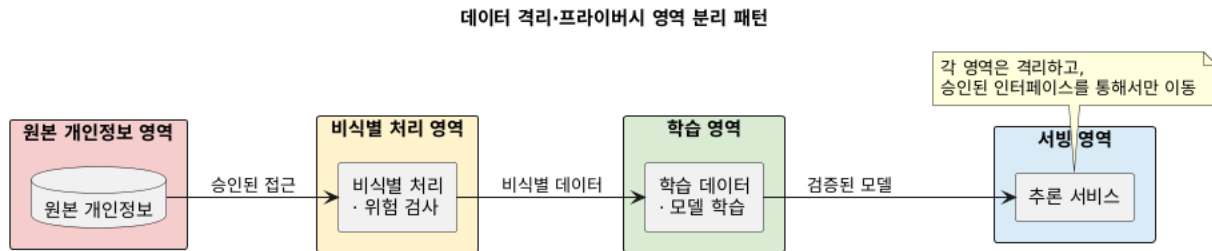
## ❖ 주의점

- 중앙 통제 컴포넌트가 단일 장애점과 병목이 될 수 있음
- 정책 서버 장애 시 기본 허용이 아니라 원칙적으로 안전한 거부(fail closed)가 필요
- 업무 목적과 동의 상태를 신뢰성 있게 관리해야 함

# 데이터 격리·프라이버시 영역 분리 패턴

## ❖ 기본 개념

개인정보의 민감도와 처리 목적에 따라 저장소와 처리 환경을 구분하고, 영역 간 이동은 승인된 인터페이스를 통해서만 허용



## ❖ 장점

- 한 영역의 침해가 전체 개인정보 유출로 확산되는 것을 제한
- 원본 데이터에 접근하는 구성요소를 최소화

## ❖ 주의점

- 영역을 나누는 것만으로 보호가 완성되는 것은 아님
- 영역 간 데이터 이동 경로에 인증·암호화·정책 검사가 필요

# 분산·로컬 우선 처리 패턴

## ❖ 기본 개념

개인정보 원본을 중앙 서버로 전송하지 않고, 사용자 장치나 데이터 보유 기관에서 처리한 후 **모델 업데이트·통계량·최소 결과만 공유**

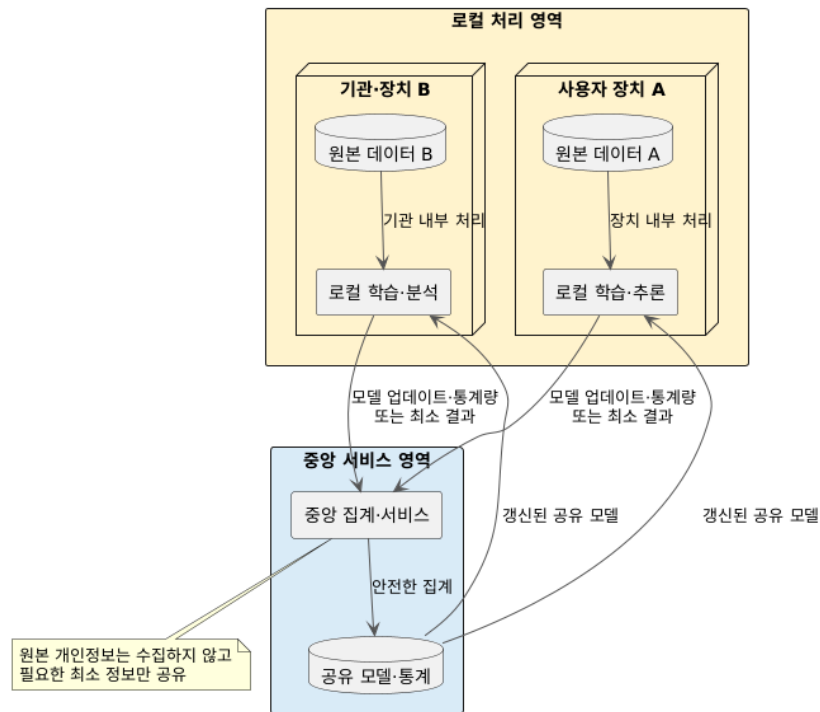
## ❖ 장점

- 원본 데이터의 중앙 집중에 따른 대규모 유출 위험 감소
- 기관 간 원본 데이터 공유 없이 공동 학습 가능
- 데이터 국외 이전이나 기관별 보유 제약에 대응 가능

## ❖ 주의점

- 모델 업데이트에서도 정보가 유출될 수 있으므로 안전한 집계 등이 필요
- 참여 기관과 단말의 신뢰 수준이 서로 다를 수 있음
- 연합학습은 개인정보 보호를 자동으로 보장하는 기술이 아님

DP-3 분산·로컬 우선 처리 패턴



## Q & A

---